Cloud security baseline for Azure Entra ID.

Overview

- Microsoft Entra ID is a cloud-based identity and access management service that your employees can use to access external resources. Example resources include Microsoft 365, the Azure portal, and thousands of other SaaS applications. Microsoft Entra ID uses intelligent password protection for cloud and on-premises. Protection includes smart lockout plus blocking common and custom password phrases and substitutions.

Security baseline for Azure Entra ID.

1. Apply principle of least privileges.

Cloud Security Capability	Cloud Security Domain	Severity
Least Access Policies	Identity and Access Management	deny

Why?

Least privilege provides exactly the permission administrators need to do their job.

Key Security Consideration

How?

Guidelines?

2. Use Privileged Identity Management to grant just-in-time access.

Cloud Security Capability	Cloud Security Domain	Severity
Privileged access management	Identity and Access Management	Not enabled

Why?

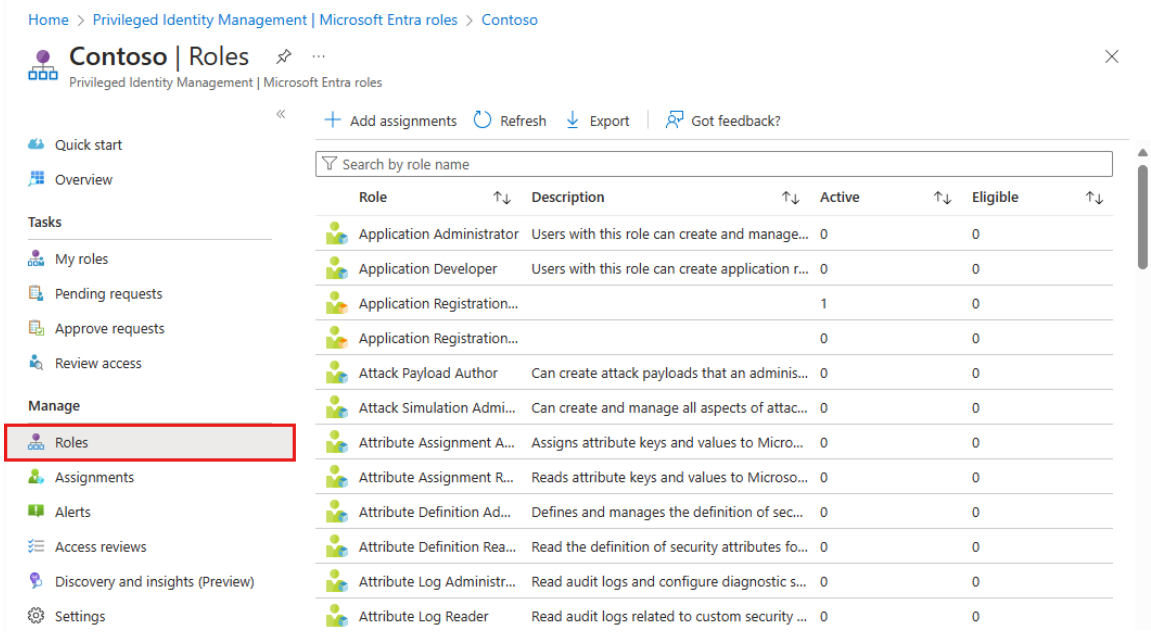
Using PIM, a user can be made eligible to activate the role for a limited time when needed.

Key Security Consideration

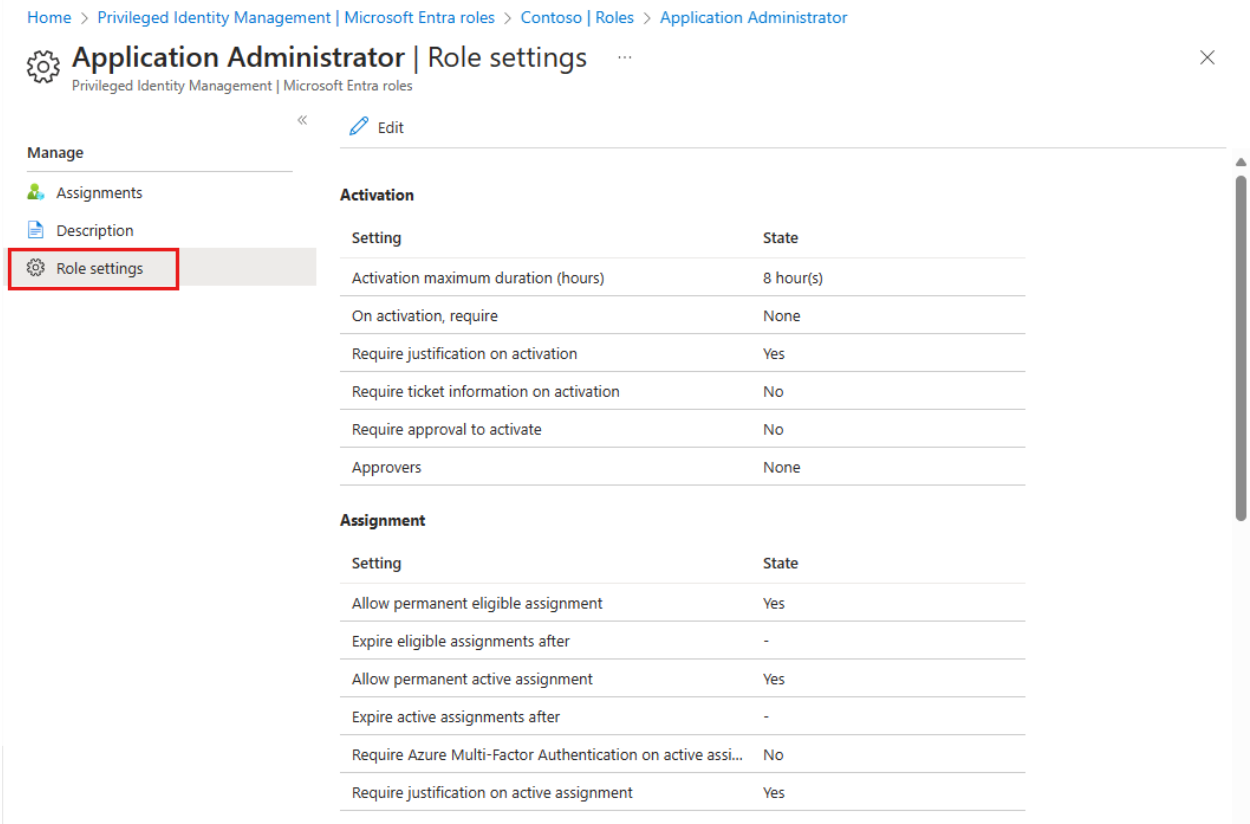
How?

Guidelines?

1. Sign in to the Microsoft Entra admin center as at least a Privileged Role Administrator.
2. Browse to **Identity governance** > **Privileged Identity Management** > **Microsoft Entra roles** > **Roles**.
3. On this page you see a list of Microsoft Entra roles available in the tenant, including built-in and custom roles.



4. Select the role whose settings you want to configure.
5. Select **Role settings**. On the **Role settings** page, you can view current PIM role settings for the selected role.



6. Select Edit to update role settings.
7. Select update.

3. Enable MFA for all privileged and non-privileged accounts.

Cloud Security Capability	Cloud Security Domain	Severity
Password Management	Identity and Access Management	Not enabled

Why?

Multi-Factor Authentication (MFA) provides an additional layer of security against unauthorized access to admin account, services, and resources.

Key Security Consideration

Enabling MFA will safeguard UL Privileged accounts and cloud resources against malicious users and attackers.

How?

Guidelines?

4. Conduct a risk-based access review for privileged accounts.

Cloud Security Capability	Cloud Security Domain	Severity
Privileged access management	Identity and Access Management	Not enabled

Why?

Access reviews enable organizations to review administrator's access regularly to make sure only the right people have continued access.

Key Security Consideration

This helps you reduce the risk of unauthorized or excessive access and maintain your compliance standards.

How?

Guidelines?

5. Limit the number of Global Admin to less than 5.

Cloud Security Capability	Cloud Security Domain	Severity
Privileged access management	Identity and Access Management	Not enabled

Why?

Users who are assigned the Global Administrator role can read and modify almost every administrative setting in your Microsoft Entra organization. With a few exceptions, Global Administrators can also read and modify all configuration settings in your Microsoft 365 organization. Global Administrators also could elevate their access to read data. Hence UL to consider a maximum of 3 global administrators.

Key Security Consideration

How?

Guidelines?

6. Limit the number of privileged role assignment to less than 10.

Cloud Security Capability	Cloud Security Domain	Severity
Least Access Policies	Identity and Access Management	Not enabled

Why?

Roles having Privileged permissions could update credentials. UL should limit the use of the privileged role assignments to fewer than 10.

Key Security Consideration.

This will minimize the risk of elevation of privilege.

How?

Guidelines?

7. Restrict access to Microsoft Entra ID administration portal.

Cloud Security Capability	Cloud Security Domain	Severity
Password Management	Identity and Access Management	Not enabled

Why?

Microsoft Entra ID administrative portal provides access to sensitive or private information; therefore, all non-admin users should be prohibited from accessing any Microsoft Entra ID resource or information available on the administration portal to avoid data exposure.

Key Security Consideration.

This will minimize the risk of data exposure.

How?

Guidelines?

Below are the steps.

Step:1 - Sign in to Azure Management Console.

Step:2 - Navigate to Microsoft Entra ID blade at

https://p ortal.azure.com/#blade/Microsoft_AAD_IAM/ActiveDirectoryMenuBlade/Overview.

Step:3- In the navigation panel, select **Users**.

Step:4- Under **All users**, select **User settings** to access Microsoft Entra ID user settings.

Step:5- On the **User settings** configuration page, under **Administration portal**,

check Restrict access to Microsoft Entra ID administration portal setting configurations.

If **Restrict access to Microsoft Entra ID administration portal** policy is set to **No**,

users without administrative privileges can use Microsoft Entra ID administration.

portal to access directory data and resources, thus the current Microsoft Entra ID

user configuration is not compliant.

Step:6- Repeat steps no. 3 – 5 for each Microsoft Entra ID that you want to examine.

8. Activate multiple roles at once using PIM for group.

Cloud Security Capability	Cloud Security Domain	Severity
Segregation of Duties	Identity and Access Management	Not enabled

Why?

PIM for groups will be used in a scenario where the eligible individual has multiple assignments to Microsoft Entra roles through PIM. This will reduce the productivity and

complexity of maintaining multiple PIM.

Key Security Consideration.

How?

Guidelines?

Create a PIM for Groups and grant it permanent access to multiple roles (Microsoft Entra ID and/or Azure). Make that user an eligible member or owner of this group. With just one activation, they'll have access to all the linked resources.

9. Disable 'Allow users to remember MFA on trusted devices.

Cloud Security Capability	Cloud Security Domain	Severity
Least Access Policies	Identity and Access Management	Not enabled

Why?

Do not allow users to remember multi-factor authentication on devices.

Key Security Consideration.

This can enhance usability by minimizing the number of times a user may need to perform two-step verification on the same device and user cannot bypass the MFA.

How?

Guidelines?

10. Do not allow direct application assignment.

Cloud Security Capability	Cloud Security Domain	Severity
Least Access Policies	Identity and Access Management	Not enabled

Why?

It is very difficult to track and monitor individual user assignments across numerous applications.

Key Security Consideration.

Directly assigning applications to users increases the risk of unauthorized access and potential misuse.

How?
1. Leverage Azure AD groups for app assignment.
2. Leverage dynamic group membership rules to automatically assign apps to users based on their attribute.

Guidelines?

11. Periodically review expired or inactive client secret/certificate.

Cloud Security Capability	Cloud Security Domain	Severity
External/remote Access	Identity and Access Management	Not enabled

Why?

Expired secrets or certificates can lead to authentication failures, making the application inaccessible to users which eventually undermines user trust in the application reliability.

Key Security Consideration.

How?

Guidelines?

1. Perform a comprehensive review to identify client with expired or inactive secrets/certificates and then update them with current credentials.
2. It is recommended to use Azure Key Vault to securely store service or application credentials like passwords and secrets.
3. As secrets are sensitive to leakage or exposure, it is recommended to rotate them

often, at least every 60 days.
4. It is recommended to always use certificate credentials whenever possible.
5. Avoid hardcoding client secrets into application code or configuration to decrease the risk of exposure.
6. Turn on Key Vault logging to monitor access to your secrets and their lifecycle.

12. Configure Azure AD Identity protection settings.

Cloud Security Capability	Cloud Security Domain	Severity
Identity Management	Identity and Access Management	Not enabled

Why?

Improperly configured Azure AD Identity Protection settings pose significant security risks regarding identities in Azure AD. Properly configured settings are essential for effectively detecting risky users and sign-ins.

Key Security Consideration.

Without proper configuration, attackers may exploit vulnerabilities and gain unauthorized access to user identities, compromising security.

How?

1. Migrate sign-in risk policies to conditional access policy for more conditions and control.
2. Migrate user risk policies to conditional access policy for more conditions and control.
3. It is recommended to regularly monitor the risk event reports to investigate identity risks to ensure timely detection and mitigation of potential threats.
4. It is recommended to configure token protection policy to reduce attacks using token theft by ensuring a token is usable only from the intended device.

Guidelines?